

Security Requirements

Standalone extract of the Phase 1 report

CSE 347/652 | DES 306/525 Usable Security and Privacy
IIIT-Delhi · Monsoon 2026 · Instructor: Dr. Arun Balaji Buduru

Phase 1: User Studies to evolve Requirements, Design and Workflows
Submission: 4 October 2026

Team: [INSERT TEAM MEMBER NAMES AND ROLL NUMBERS]

Primary research status: instruments complete; fieldwork data not yet collected. All placeholders are marked [DATA REQUIRED]. No primary data has been fabricated.

20. Security Requirements

Each requirement lists: rationale, the user need it serves, the threats it addresses (IDs from Section 24), priority, the prototype feature that embodies it, and how it will be evaluated in Phase 2.

ID	Requirement	Rationale	User need	Threats	Pri	Prototype feature	Phase 2 evaluation
SEC-01	Only credentials that pass cryptographic authentication (challenge–response with a per-credential key, or valid signature on a fresh token) are accepted. Bare identifiers (UID, static QR) are never accepted.	Static identifiers are copyable; every documented breach [4–9] involved accepting data rather than proving key possession.	Students: confidence that a photo of their card cannot be used. Guards: fewer judgement calls.	TH-01 theft, TH-02 clone, TH-03 replay, TH-06 fake	M	Screen 3 "Verifying credential" → screen 6 "NOT RECOGNISED" for any unauthenticated read	Present cloned UID, static QR, replayed token → all DENY. Unit tests on verifier.
SEC-02	Revoked credentials must not grant access at any gate, online or offline, after the propagation deadline.	Complete mediation [14]; hotel breaches [8, 9] lacked this.	Meher: lost card must stop working. Guards: know a card is blocked.	TH-08 revoked reuse, TH-01	M	Screen 8 "REVOKED"; screen 18 revoke flow; offline list in screen 11	Revoke → tap within 30 s online and after sync offline → DENY.
SEC-03	Expired credentials must not grant access; expiry is enforced by the server/reader, not by a printed date.	H2: guards do not read dates.	Guards: no date reading. Admin: automatic enforcement.	TH-07 expired reuse	M	Screen 7 "EXPIRED"	Set expiry in past → DENY. Boundary tests at expiry instant.
SEC-04	Authentication must resist replay: card/NFC via server-generated nonce in challenge–response; QR via time-bound signed token with server-side replay cache; visitor pass via single/limited-use counter.	Replay is the cheapest attack on any transmitted credential.	Students: recording a tap must be useless.	TH-03 replay	M	Screen 3 (nonce exchange not visible to user; described in spec); screen 9 for detected replay	Capture and replay reader traffic and QR → DENY; second use of single-use pass → DENY.
SEC-05	All reader↔server and app↔server communication is protected with TLS 1.3 [39] with mutual authentication (reader client certificates); no plaintext or downgraded channels.	Network attacker and rogue reader.	—	TH-11 interception, TH-12 MITM, TH-16 device	M	Screen 11 shows "secure connection lost" state	TLS config scan; attempt plaintext/downgrade → connection refused.
SEC-06	Secrets (card keys, signing keys, tokens, nonces, session keys) must never appear in logs, UI, error messages, URLs, or analytics. Logs store only pseudonymous IDs and decision codes.	OWASP logging guidance [29].	Privacy; insider misuse.	TH-13 privacy leak, TH-17 insider	M	Screen 19 shows only pseudonymous IDs and codes	Grep logs and UI for key material in test runs; code review.
SEC-07	Role-based access control with least privilege [14]: Guard (view decision, record manual event, request supervisor); Supervisor (approve manual entries, view gate status); Issuer (issue/revoke credentials); Approver (visitor passes); Auditor (read logs, re-identify with justification); Policy Admin (edit policies). No role has all permissions. Separation of duties: Issuer ≠ Auditor.	Insider abuse, privilege escalation.	Guards: not responsible for data they don't need.	TH-09 escalation, TH-17 insider	M	Screens 16, 17, 19, 20 each show role-limited views	Attempt cross-role actions via API → 403; review of role matrix.
SEC-08	The guard interface displays only: photo on file, display (first) name, role, decision, reason code, next step. Never roll number, phone, address, hostel, e-mail, or revocation reason.	Minimisation; guards should not be a data-exposure vector.	Ramesh: does not want to hold personal data. Meher: dignity on denial.	TH-13, TH-17	M	Screens 5, 7, 8, 9, 16	UI inspection; API response schema test.
SEC-09	Every failure (authentication, authorization, reader, network, database, power) results in DENY or in Manual Verification Mode; no failure state opens the gate or auto-allows.	Fail-safe defaults [14].	—	TH-14 DoS, TH-15 outage, TH-16 device	M	Screens 6, 10, 11, 12	Fault injection: kill network, DB, reader mid-transaction → DENY/manual, never ALLOW.
SEC-10	Every access decision and every administrative action is written to an append-only, integrity-protected log (hash-chained; periodic signed checkpoints) with synchronised timestamps.	Auditability; repudiation.	Admin: investigate incidents. Students: trust that logs cannot be silently edited.	TH-15 log tamper, TH-17	M	Screen 19 log view with integrity status indicator	Modify a log record → verification fails; audit of chain.
SEC-11	Administrative operations (issue, revoke, policy change, re-identify, approve manual entry) require multi-factor authentication of the administrator and, for revoke/policy/re-identify, a two-step confirmation.	High-impact operations need stronger assurance [1].	—	TH-09, TH-17, TH-10 DB	M	Screens 17, 18, 20 show MFA and confirm steps	Attempt admin action with single factor → refused; attempt without confirm → not applied.
SEC-12	All credential lifecycle operations are authenticated, authorised per SEC-07, and logged per SEC-10, including who, when, which credential, and reason.	Lifecycle integrity.	—	TH-17, TH-06	M	Screens 17, 18	Log inspection after each lifecycle test.

ID	Requirement	Rationale	User need	Threats	Pri	Prototype feature	Phase 2 evaluation
SEC-13	Repeated failed attempts (≥ 3 on one credential ID in 5 min, or ≥ 5 unknown credentials at one reader in 5 min; thresholds configurable) escalate to DENY–suspicious, alert the supervisor, and rate-limit the reader.	Detect brute force, cloning trials, probing.	Guards: told when something is off.	TH-02, TH-06, TH-14	S	Screen 9 "SUSPICIOUS"; screen 16 alert	Scripted repeated attempts → escalation observed and logged.
SEC-14	The system stores only the personal data required: identity ID, display name, photo, role, programme/department, credential IDs/keys, validity, status. It does not store phone, address, emergency contact or any field not used by an implemented function.	Minimisation reduces breach impact.	Students: less to leak.	TH-10 DB compromise, TH-13	M	Screen 17 shows only these fields	Schema review; DPIA checklist.
SEC-15	Log integrity per SEC-10; additionally, logs are write-only for all roles except Auditor (read); no role can delete or edit; retention deletion is a scheduled, logged process.	Prevent cover-up of insider actions.	—	TH-15, TH-17	M	Screen 19: no edit/delete controls	Attempt delete via API → refused; verify scheduled purge logs itself.
SEC-16	Visitor passes are bound to a time window, gate set, and host; expire automatically; are single- or limited-use; and cannot be reissued without new approval.	Temporary credentials must not become permanent.	Visitors: clear validity. Guards: no judgement about "is this still OK".	TH-05 malicious visitor, TH-07	M	Screens 14, 15 show window and gate binding	Use pass after window / at wrong gate / twice → DENY.
SEC-17	Lost or stolen credentials are revocable by the holder (self-service, immediate) and by an Issuer; revocation is irreversible for that credential (a new credential is issued instead).	Remove attacker's window; avoid "un-revoke" confusion.	Meher: block card from her phone at once.	TH-01, TH-08	M	Screen 18	Self-revoke → immediate DENY; attempt to reactivate → refused.
SEC-18	Readers are treated as potentially compromised: each holds only its own client certificate and the offline verification material (public keys, signed revocation list), never master keys or the identity database; reader firmware is signed; tamper events are logged; a reader's certificate can be revoked server-side.	Onity [36] and DESFire side-channel [7] show devices leak.	—	TH-16 device compromise, TH-11	M	Screen 10 reader failure/tamper state	Extract reader storage in test → no master key present; revoke reader cert → server refuses it.
SEC-19	Defined secure behaviour during network/database failure: readers verify offline with cached public keys and a signed revocation list $\leq N$ hours old (N configurable, e.g., 4); beyond N , or without cached material, enter Manual Verification Mode (FR-14, FR-19). No unconditional ALLOW.	Availability with bounded staleness.	Students: not stranded. Guards: know what to do.	TH-14, TH-15 outage	M	Screens 11, 12	Fault injection with clock advance → mode transitions as specified.
SEC-20	Security must not depend on secrecy of the design, protocol, or code (open design [14]). Only keys are secret. All cryptography uses standard primitives and vetted libraries (AES-128/256, Ed25519 [38], SHA-256, TLS 1.3 [39]); no custom algorithms.	Course brief; established principle.	—	All	M	N/A (design property)	Design review; dependency audit.

Note on what SEC requirements do not claim. They do not claim the system cannot be attacked. Residual risks (relay, coerced or fatigued guard, compromised phone, future chip break) are recorded in Section 24 with the compensating controls.